SHIELD-AI

Security and Holistic Integrity for Enterprise-Level Deployment of AI

Technical Deep Dive — Framework Architecture, Controls & Implementation

Security Architecture Practice · v1.1 · July 2026

Agenda

1. Architecture Overview

- Reference architecture — control stack
- Threat landscape & attack taxonomy

2. Six Pillars Deep Dive

- MS · IAM · DS · TP · MIR · GRM
- Controls, decision trees, mappings

3. Regulatory & Standards

- AU frameworks, OWASP, NIST, EU AI Act, ISO 42001

4. Emerging Trends & Protocol Security

- Multi-agent, MCP, persistent memory, code-gen agents

5. Delivery & Operations

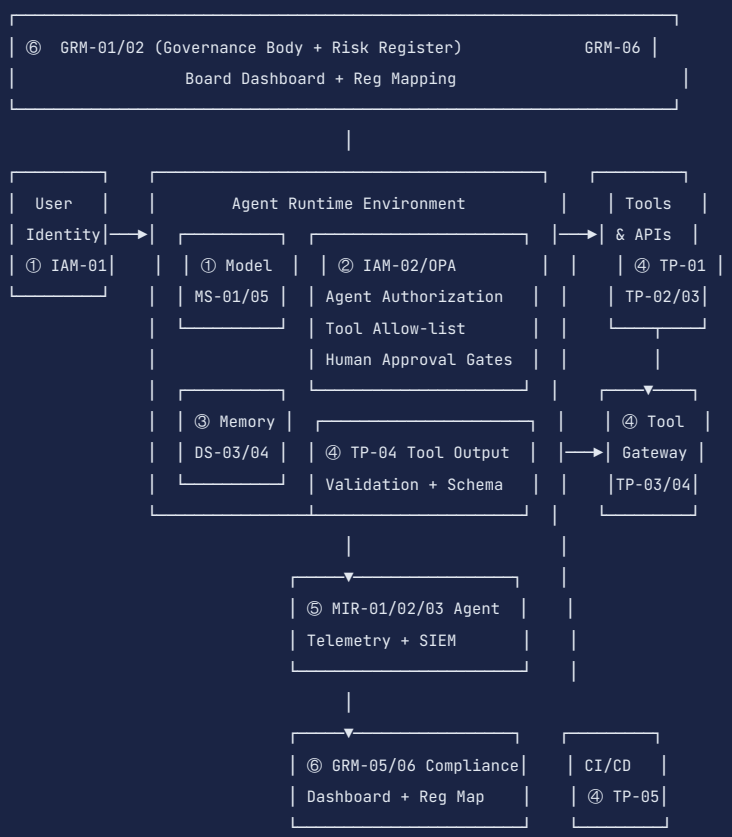
- Implementation methodology, continuous compliance
- Build-vs-buy, deployment topologies, service tiers

6. Reference & Appendices

- Frameworks comparison, glossary, try-it-now

Reference Architecture — SHIELD-AI Control Stack

This is the anchor for every pillar. Each numbered area maps to a SHIELD-AI pillar.



Agentic AI Threat Landscape

Six layers of attack surface — controls must cover all of them

MODEL LAYER

Prompt injection, jailbreaking, model inversion, data extraction from responses, backdoor triggers

DATA LAYER

Cross-session data aggregation, RAG pipeline poisoning, PII leakage in tool calls

TOOL LAYER

Tool output injection, malicious tool registration, API abuse, tool chain poisoning

PIPELINE LAYER

CI/CD compromise, model update substitution, dependency chain poisoning

IDENTITY LAYER

Credential delegation abuse, session hijacking, privilege escalation via agent-to-agent

🏛 GOVERNANCE LAYER

Shadow AI, uncontrolled agent proliferation, missing audit trails across agent chains

Why Existing Frameworks Don't Cover Agentic AI

ASD ISM (1,081 CONTROLS)

Zero AI-specific controls. March 2026 "Guidelines for secure AI system development" is introductory, not a control framework.

ESSENTIAL EIGHT

Necessary but insufficient — doesn't address prompt injection, tool delegation, agent identity.

NIST AI RMF

Risk management process — not an implementable control framework. No technical control specifications.

OWASP LLM TOP 10

Threat taxonomy, not a framework with maturity levels, implementation guidance, or regulatory mapping.

EU AI ACT

Risk classification + obligations. No technical controls defined.

ISO/IEC 42001:2025

AI management system — defines governance processes, no technical security controls.

SHIELD-AI Framework — 6 Pillars × 36 Controls

P1
Model Security
Weight protection, training integrity, supply chain, adversarial robustness, behaviour validation, inventory

P2
Identity & Access
Agent identity, scope-bound delegation, human oversight, credential isolation, JIT access, cross-session

P3
Data Security
Classification, inference protection, memory sanitisation, minimisation, training governance, output validation

P4
Tool & Pipeline
Tool registry, access control, API gateway, output validation, pipeline integrity, dependency scanning

P5
Monitoring & IR
Activity logging, anomaly detection, prompt audit, IR playbooks, reporting integration, forensic readiness

P6
Governance & Risk
Governance body, risk register, ethical use, third-party risk, regulatory mapping, board reporting

36 controls · 4 maturity levels · Mapped to 7+ AU and international frameworks

SHIELD-AI vs "We Already Use NIST + OWASP + ISO 42001"

The most common technical objection, answered directly

Dimension	NIST AI RMF + OWASP + ISO 42001	SHIELD-AI
Framework count	3 separate, each with different terminology	1 unified framework
Maturity model	None — no "where are we → where next"	4 levels (L1-L4) with per-control progression
AU regulatory mapping	None — must build custom mapping	Full ISM/E8/SOCI/CPS 234/PSPF/Privacy Act
Agentic-AI specificity	Partial — NIST AI RMF covers general AI risk	Full — 6 pillars designed for autonomous agents
Technical controls	No — process/procedure only	36 implementable controls
Implementation guidance	None — "establish a risk management process"	Per-control guidance: OPA policies, gateway configs, SIEM rules
Continuous compliance	No — point-in-time assessment	Roadmapped — policy-as-code, automated testing
Professional services available	Yes, from multiple vendors (inconsistent)	Single consultancy, consistent methodology
Time to L3 maturity	12-18 months (build-your-own)	12-16 weeks (SHIELD-AI Standard)

SHIELD-AI does not replace these frameworks — it integrates them into a single, AU-specific, implementable control framework with a maturity model and delivery methodology.

Pillar 1: Model Security (MS)

MS-01	**Weight protection** — encrypt at rest/transit, HSM-backed keys, remote attestation for edge	ISM
MS-02	**Training data integrity** — provenance tracking, sanitisation, poison detection pipeline	ISM LLM04
MS-03	**Supply chain** — model provenance, ML SBOM, signed checkpoints	ISM LLM10
MS-04	**Adversarial robustness** — prompt injection testing, jailbreak eval, auto red-teaming	LLM01 NIST
MS-05	**Behaviour validation** — ouput guardrails, content filtering, behavioural bounds	LLM02
MS-06	**Model inventory & lineage** — catalogue all models, versioning, deployment tracking	

DECISION TREE: CHOOSING YOUR APPROACH

How to approach model security:

Q: Do you use third-party or self-hosted models?

> Third-party → focus on MS-04 (prompt injection testing), MS-05 (output guardrails)

> Self-hosted → add MS-01 (weight encryption), MS-02 (training integrity)

Q: How many models in production?

> <5 → Manual inventory (MS-06 spreadsheet)

> 5+ → Deploy model registry with signing at every stage

Q: Do agents use RAG?

> Yes → Implement RAG security layer for DS-01/DS-04 in parallel

> No → Defer RAG controls to Phase 2

AU MAPPINGS

ISM: secure AI system dev, system hardening, procurement. ASD supply chain guidance (Mar 2026).

Pillar 2: Identity & Access (IAM)

IAM-01	**Agent identity** — unique service identities per agent, not human credential sharing	ISM E8
IAM-02	**Scope-bound delegation** — tools scoped to agent function, no wildcards, no self-escalation	LLM08
IAM-03	**Human oversight** — approval gates for high-risk actions, break-glass with audit trail	
IAM-04	**Credential isolation** — agent creds separate from human, hardware-backed for L3+	
IAM-05	**JIT access** — ephemeral credentials, auto-revocation after session	
IAM-06	**Cross-session boundary** — independent identity contexts per session	

DECISION TREE: CHOOSING YOUR APPROACH

Choosing your agent identity approach:

Q: How many agents?

> <5 → OPA sidecar per agent (simplest path)
>
> 5-50 → Central OPA gateway (single policy enforcement point)
>
> 50+ → OPA + SPIFFE/SPIRE for workload identity (scales)

Q: Multi-agent architecture?

> Yes → Add bounded delegation chain (IAM-02 extended)

Q: Agents generate code?

> Yes → Code execution = highest-class tool: requires human approval for production writes

AU MAPPINGS

ISM: system management (privileged access, auth). E8: Restrict Admin Privs, MFA, App Hardening. PSPF: Personnel Security.

Pillar 3: Data Security (DS)

DS-01	**Data classification** — automated tagging per PSPF/ISM at ingestion	ISM
DS-02	**Inference protection** — TLS 1.3, end-to-end encryption of prompts/responses	
DS-03	**Memory sanitisation** — no sensitive data across sessions; retention policies; automated purging	LLM06
DS-04	**Data minimisation** — field-level filtering in retrieval layer, no bulk data	
DS-05	**Training data governance** — lineage, consent verification, retention limits	
DS-06	**Output validation** — scanning for PII, training data leakage, system prompt exposure	LLM02

DECISION TREE: CHOOSING YOUR APPROACH

How to approach data security:

Q: Does your agent use persistent memory?

> Yes → DS-03 is highest priority: retention policies, automated purging, per-agent scoping

> No → Defer DS-03, focus on DS-01 (classification) and DS-04 (minimisation)

Q: RAG pipeline?

> Yes → Implement ABAC at retrieval time, field-level redaction before context injection

Q: Regulated data (PII, financial, health)?

> Yes → DS-02 (encryption), DS-06 (output scanning), Privacy Act mapping required

AU MAPPINGS

Privacy Act (APP 11, 5, 6). ISM: data transfers, media, crypto. SOCI: CIRMP data obligations. PSPF: sensitive info.

Pillar 4: Tool & Pipeline Security (TP)

TP-01	**Tool registry** — all tools registered, versioned, security-approved	
TP-02	**Tool access control** — least-privilege per agent, tool authenticates agent	
TP-03	**API gateway** — rate limiting, schema validation, audit logging on agent-facing APIs	
TP-04	**Tool output validation** — structural validation, sanitisation before agent context	LLM02
TP-05	**Pipeline integrity** — signed, attested CI/CD with security gates	
TP-06	**Dependency scanning** — continuous vuln scanning, auto-block critical findings	LLM10

DECISION TREE: CHOOSING YOUR APPROACH

Choosing your deployment topology:

> <10 agents → Embedded library (simplest, framework-native)
>
> 10-100 agents → Sidecar proxy (balanced isolation vs overhead)
>
> 100+ / multi-agent → Central gateway for external, sidecars for cross-agent

Q: Using MCP protocol?

> Yes → Deploy MCP-aware gateway: validates tool discovery, schema enforcement at protocol layer

Q: Code-generating agents?

> Yes → Sandbox execution + output verification required at L2+

AU MAPPINGS

ISM: gateways, networking, software dev, sys mgmt. E8: Patch Apps, Patch OS, App Control. SOCI: tech security.

Pillar 5: Monitoring & IR (MIR)

MIR-01	**Activity logging** — every tool call, data access, decision; agent ID + session + correlation ID	
MIR-02	**Anomaly detection** — per-agent and per-class baselines; deviation alerts	
MIR-03	**Prompt audit log** — sanitised prompt/response pairs, recoverable for IR	
MIR-04	**IR playbooks** — prompt injection containment, model rollback, tool revocation	
MIR-05	**Mandatory reporting** — automated SOCI 12h / APRA 72h / NDB triggers	SOCI, CPS 234
MIR-06	**Forensic readiness** — immutable append-only logs, full session reconstruction	

DECISION TREE: CHOOSING YOUR APPROACH

How to build agent telemetry:

Q: Existing SIEM?

> Splunk/SOAR/ELK → Deploy agent telemetry as structured JSON events via OTLP

> None → Start with cloud logging (CloudWatch, Azure Monitor, GCP Cloud Logging)

Q: Multi-agent architecture?

> Yes → Distributed tracing header across all agents; single audit trail per user request chain

Q: Regulated sector?

> Yes → MIR-05 (reporting automation) is critical: pre-populated SOCI/APRA/NDB templates

AU MAPPINGS

SOCI (s.30B). APRA CPS 234 (72h). ISM: monitoring, incidents, forensics. Privacy Act: NDB scheme.

Pillar 6: Governance & Risk (GRM)

GRM-01	**AI governance body** — CISO, CRO, GC, data owner, AI lead with charter	CPS 234
GRM-02	**AI risk register** — distinct taxonomy for model/tool/data/identity/pipeline risks	
GRM-03	**Ethical use policy** — acceptable use, human-in-the-loop by risk tier, transparency	
GRM-04	**Third-party AI risk** — vendor assessment, contractual controls, right-to-audit	LLM10
GRM-05	**Regulatory mapping** — automated ISM/E8/SOCI/CPS 234/PSPF mapping, quarterly reports	
GRM-06	**Board reporting** — dashboard: maturity per pillar, findings, compliance status, risk acceptances	

DECISION TREE: CHOOSING YOUR APPROACH

How to build AI governance:

Q: Existing risk/compliance function?

> Mature (APRA-regulated) → GRM-01 (chartered committee), GRM-02 (risk register), GRM-05 (automated mapping)

> Developing → Start with GRM-06 (dashboard — shows posture without formal governance)

Q: Using external model providers?

> Yes → GRM-04 mandatory: vendor assessment, right-to-audit, SLA for security

Q: Multiple business units?

> Yes → GRM-01 expanded: cross-entity governance body with representatives from each unit

AU MAPPINGS

APRA CPS 234 (Board). PSPF: Security Gov. SOCI: CIRMP. Privacy Act APP 1. ISM: roles, documentation.

Maturity Model — Level-Up Guidance

Area	L1 Initial	L2 Managed	L3 Defined	L4 Optimised	How to Level Up (example: IAM)
MS	Basic inventory	Supply chain verification	Adversarial testing programme	Automated red-teaming	L1→L2: Sign ML SBOMs. L2→L3: Deploy CI/CD prompt injection tests. L3→L4: Continuous red-teaming.
IAM	Shared credentials	Per-agent service accounts	JIT access, approval gates	Continuous rotation	L1→L2: Each agent gets identity. L2→L3: OPA gateway + ephemeral creds. L3→L4: SPIFFE/SPIRE auto-rotation.
DS	Basic classification	Memory sanitisation	E2E inference encryption	Real-time leak detection	L1→L2: Auto-classify at ingestion. L2→L3: RAG security layer. L3→L4: Real-time output scanning.
TP	Informal tool list	Tool registry + access control	API gateway + schema validation	Auto dependency scanning	L1→L2: Register all tools. L2→L3: Deploy tool gateway. L3→L4: Continuous vuln scanning.
MIR	Basic logging	Structured audit logs	Anomaly detection, IR playbooks	AI-specific SIEM	L1→L2: Structured JSON events. L2→L3: Per-agent baselines. L3→L4: AI-specific SIEM rules.
GRM	No governance	AI risk register	Board reporting, reg mapping	Continuous attestation	L1→L2: Create AI risk register. L2→L3: Automated compliance mapping. L3→L4: Continuous dashboards.

● L1→L2: 3-4 months ●● L1→L3: 8-12 months ●●●● L3→L4: 12+ months

MCP Protocol & Agent-Tool Interface Security

SECURITY BENEFITS OF MCP

Standardised interfaces enable standardised controls. MCP defines tool discovery schemas, typed tool interfaces (JSON Schema), and structured error responses — making generic tool security proxies possible.

MCP ATTACK SURFACE

Tool discovery poisoning, capability advertisement manipulation, protocol-level prompt injection through tool descriptions, MCP gateway bypass.

SHIELD-AI MCP CONTROLS

TP-03 extended: MCP gateway enforces auth, schema validation, rate limiting at protocol layer. **TP-04 extended:** MCP response validation against known-good schemas. **MS-04 extended:** MCP protocol-layer adversarial testing.

MCP GATEWAY ARCHITECTURE

```
Agent → MCP Gateway (proxy) → Tool Server
          |
          ├─ Authenticate agent identity
          ├─ Validate tool discovery response
          ├─ Enforce allow-list per agent
          ├─ Validate request/response schema
          ├─ Rate limit per agent+tool
          ├─ Audit log every invocation
          └─ Fail closed if audit down
```

Emerging: Multi-Agent Systems & Agent Swarms

ARCHITECTURE CHANGES

- **Delegate** tasks to other agents — delegation chains
- **Share context** — one agent's output is another's input
- **Coordinate** — interdependent multi-agent workflows

BLAST RADIUS MULTIPLIER

A single compromised agent poisons every downstream agent's context. Prompt injection impact scales from one tool chain to the entire swarm.

IAM-02: BOUNDED DELEGATION CHAIN

Agent-to-agent must not expand original scope. Each hop respects bounds — no escalation across delegation chains.

MIR-01: DISTRIBUTED TRACING

Single user request → chain of agent calls reconstructable as one audit trail. Requires **distributed tracing header** propagated across all agents.

TP-01: A2A AS TOOL CLASS

Agent-to-agent APIs registered, versioned, security-approved — same rigour as external tool endpoints.

TIMELINE

Production 2026. Dominant by 2027-28. L3 clients plan now.

Emerging: Persistent Agent Memory

DATA AGGREGATION RISK

- Agent remembers User A's financial details
- User B queries in Session 2 — cross-reference possible
- Memory embedding spaces encode sensitive correlations

ATTACK VECTORS

Memory-read: compromised session reads another session's data.
Memory poisoning: crafted inputs trigger unintended behaviour on retrieval.

DS-03: MEMORY SANITISATION (HIGHEST PRIORITY)

Retention policies with automated purging. Cross-session aggregation detection. Per-agent memory scoping. Encryption at rest.

DS-04: MEMORY MINIMISATION

Only essential data remembered. Memory scoped per-agent and per-task — not shared across agents by default.

MIR-02: MEMORY ACCESS ANOMALY DETECTION

Baseline memory access patterns. Agent accessing weeks-old records = compromise indicator. Cross-agent memory access = policy violation.

Emerging: Autonomous Code Generation

The highest-risk agent capability — treat accordingly

Level	Capability	Human Approval
1	Generate SQL queries	Always
2	Generate shell commands	Always
3	Generate config files	Always
4	Self-heal — patch own code	Always + sandbox
5	Write and deploy microservices	Multi-party approval

TP-01: CODE EXECUTION AS TOOL CLASS

Distinct class with highest security. Must be explicitly enabled per agent — never default-on.

TP-04: CODE OUTPUT VALIDATION

Sandbox-executed and output-verified before production. Human review gate for infra-modifying code.

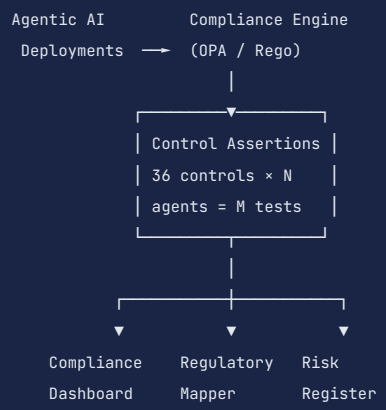
MIR-04: CODE INJECTION PLAYBOOK

Different containment: revoke code-exec tool, rollback affected systems, audit recently generated code.

AU Regulatory Mapping

SHIELD-AI	ISM	E8	SOCI Act	CPS 234	Privacy Act
MS-01	Cryptography	-	CIRMP s.4(a)	s.3(b)	APP 11
IAM-01	Sys Mgmt	Restrict Priv	-	s.3(b)	-
IAM-02	Sys Mgmt	-	CIRMP s.4(b)	s.3(a)	-
DS-01	Data Transfers	-	-	s.3(a)	APP 5,6
DS-03	Media	-	-	-	APP 11
TP-01	Gateways	Patch Apps	CIRMP s.4(c)	s.3(b)	-
MIR-01	Monitoring	-	s.30B(5)(a)	s.3(c)	NDB
MIR-05	Incidents	-	s.30B(5)(c)	s.3(c)	NDB
GRM-01	Roles	-	CIRMP s.4(d)	s.2	APP 1

Continuous Compliance Automation



1. CONTROL AS CODE

Every SHIELD-AI control = machine-readable assertion (Rego policy, CI/CD test, etc.)

2. CONTINUOUS TESTING

Critical controls: every 15 min. Config controls: daily. Dashboard with trend data.

3. REGULATORY CHANGE DETECTION

Automated monitoring of ISM updates, new legislation, OAIC/APRA guidance. Impact analysis per control.

4. EVIDENCE AUTOMATION

Automated collection of logs, configs, attestations. Replaces 60%+ of manual assessment effort.

Deployment Topologies — Decision Tree

<10 AGENTS

Embedded library — security controls via agent framework SDK/plugin. Low latency, simple config. Best for: pilots, single-agent PoCs.

PROS

No infra dependency, consistent with framework API

CONS

Framework-dependent, bypassable if agent code modified

10-100 AGENTS

Sidecar proxy — per-agent sidecar (OPA + tool gateway + telemetry). Best for: K8s deployments, existing service mesh.

PROS

Isolation per agent, no SPOF, consistent with sidecar mesh

CONS

Resource overhead, config drift at scale

100+ / MULTI-AGENT

Central gateway + sidecar audit — gateway for external tools, sidecars for cross-agent monitoring. Best for: enterprise, regulated, multi-agent systems.

PROS

Single policy point, central audit, distributed scale

CONS

Complexity, requires service mesh maturity

Build-vs-Buy Analysis

Factor	Build In-House	SHIELD-AI
Time to capability	12-18 months	4-16 weeks
Hiring	3-5 specialists (6-9mo to hire)	None — consultancy delivers
Framework depth	Inexperienced, likely gaps	36 controls, 7+ framework mappings
Regulatory confidence	Low — untested	High — auditable mappings
First-year cost	$600K-$1.2M (salaries + tools)	$25K-$800K (tier-dependent)
Ongoing cost	$500K-$800K/yr (retention)	$50K-$800K/yr (assurance)

BEST CASE

Lite ($25K) identifies 2-3 critical gaps. Client closes internally. ROI: avoided $1.78M+ breach.

EXPECTED CASE

Standard ($150K). L3 in 4 months. Auditable compliance vs $1.2M build cost.

WORST CASE

Lite finds client not ready for agentic AI. $25K saves them from deploying insecure AI leading to $500K+ remediation.

Service Tiers — Technical Summary

Capability	Lite ($25-45K)	Standard ($120-250K)	Enterprise ($400-800K+/yr)
Assessment scope	1-3 systems / pilots	Full agentic AI estate	Multi-entity / cross-border
Control implementation	Action plan only	Full L3 deployment	Custom control development
Technical tooling	Assessment scanner	OPA policies, gateway, dashboards	+ Threat intel, red-teaming platform
Regulatory mapping	Applicable frameworks	All AU + international	Continuous + advocacy support
Staffing	2 consultants, 2-3 wks	2-3 consultants, 12-16 wks + 6mo	Embedded architect + full team
Target maturity	L1→L2 awareness	L3 defined	L4 optimised

Key Technical Terms

Term	Definition	Control
MCP	Standardised protocol for agent-tool discovery and invocation	TP-03, TP-04
A2A Protocol	Standard for direct inter-agent communication and delegation	IAM-02, MIR-01
Policy-as-Code	Security policies as machine-readable, testable assertions (OPA/Rego)	GRM-05, IAM-02
Tool Output Injection	Compromised tool returns crafted data to manipulate agent behaviour	TP-04, DS-06
Agent SBOM	Software bill of materials: model, tools, libraries, pipeline, runtime	MS-03, TP-06
RAG Security Layer	ABAC at retrieval + field-level redaction before model context	DS-01, DS-04
Agent Telemetry	Structured event stream: tool calls, data access, decisions, errors	MIR-01, MIR-02
Bounded Delegation	Each agent-to-agent hop respects original scope — no escalation	IAM-02
Continuous Compliance	Control verification runs continuously, not point-in-time	GRM-05, GRM-06
MCP Gateway	Security proxy for MCP protocol: auth, schema, audit, rate-limiting	TP-03

Try It Today — Reference Implementation

GITHUB: SHIELD-AI/REFERENCE

Open-source OPA policies, tool gateway proxy, and agent telemetry pipeline. Clone, deploy, test.

ASSESSMENT TOOLKIT

One command: `shield-ai assess /deployments` — inventory your AI agent estate, score against 36 controls.

REQUEST EARLY ACCESS

Contact: practice-lead@consultancy.example.com. Full assessment toolkit available under NDA.

Questions & Discussion

SHIELD-AI v1.1 — July 2026

Security Architecture Practice

Full framework document (30-page PDF) • Business decision-maker deck (12 slides) • All available on request